DAY32-Authentication Failures & Secure Login

Q1 — Authentication Fundamentals [2 Marks]

Authentication is the process of verifying a user's identity before allowing them to access a system.

Two examples of authentication factors are:

1. Password or PIN.
2. Security key or authentication device.

Q2 — Authentication vs Authorization [2 Marks]

Authentication verifies who a user is, while authorization determines what the user is allowed to access.

For example:

A student logs into a university portal using their username and password (authentication).

Student can only view their own marks and assignments (authorization).

Q3 — Username Enumeration [3 Marks]

Username enumeration is a vulnerability that allows attackers to determine whether specific usernames exist in an application.

Two examples are:

1. Displaying different error messages such as Invalid username and Incorrect password.
2. Returning different HTTP response lengths, status codes, or response times depending on whether the username exists.

Q4 — Brute Force & Credential Stuffing [3 Marks]

(a) **Brute-force attack**: An attacker repeatedly tries different passwords or combinations until the correct credentials are discovered.

(b) **Credential stuffing**: An attacker uses previously leaked username and password combinations to attempt logins on other websites.

DAY32-Authentication Failures & Secure Login

Q5 — Authentication Defenses [3 Marks]

1. **Rate limiting**: Restricts repeated login attempts within a specific period, reducing automated attacks.
2. **Multi-Factor Authentication (MFA):** Requires an additional verification factor, providing protection even if a password is compromised.
3. **Generic login error messages:** Displays the same error for invalid usernames and passwords, preventing attackers from easily identifying valid accounts.

Q6 — Password Reset [2 Marks]

A secure password-reset mechanism should:

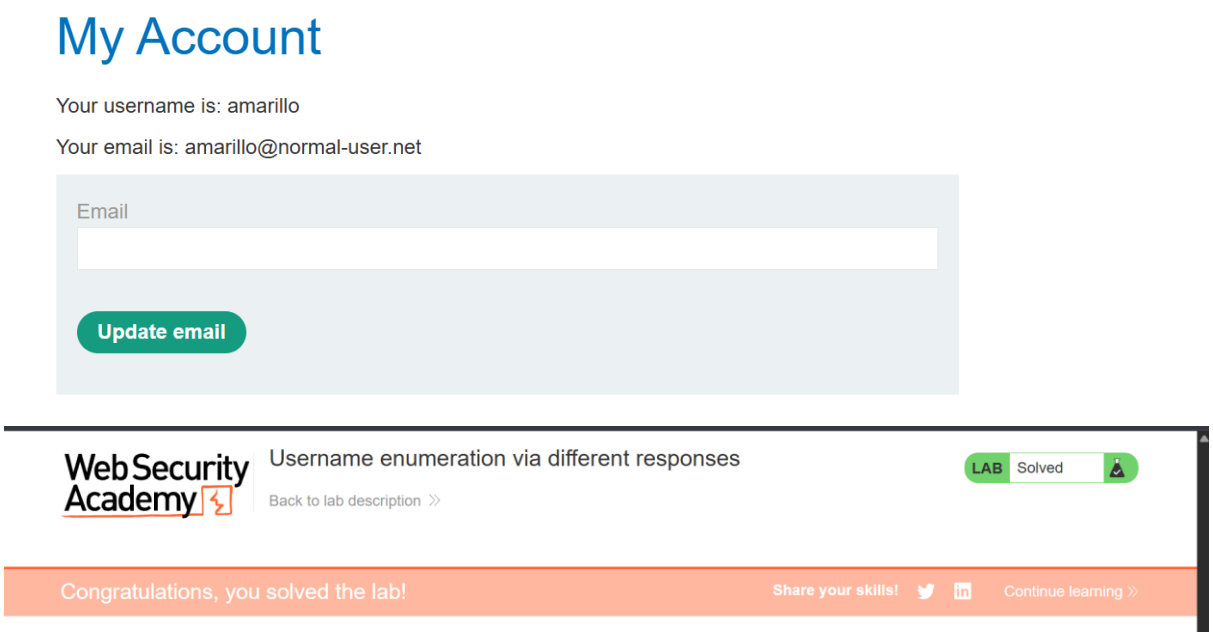
1. Generate random, unpredictable reset tokens.
2. Set a short expiration time for reset links.
3. Allow each reset token to be used only once.
4. Verify the user's identity and securely invalidate the token after a successful password reset.

Q7 — Practical Lab [3 Marks]

Lab: PortSwigger – Username Enumeration via Different Responses.

1. **Vulnerability observed**: The application was vulnerable to username enumeration and password brute-force attacks.
2. **Information leakage**: The application displayed Invalid username for nonexistent accounts and Incorrect password for valid usernames with incorrect passwords. Using Burp Suite Intruder, the username amarillo was identified, and the lab password 777777 produced an HTTP 302 Found redirect to the account page.
3. **Mitigation**: Developers should implement generic login errors, rate limiting, MFA, and monitoring for suspicious login attempts.

DAY32-Authentication Failures & Secure Login



Q8 — Secure Login Design [2 Marks]

For the Jayvik Labs Student Portal, these are the following security controls:

1. Strong password policy: Require long, unique passwords and securely hash them.
2. Multi-Factor Authentication (MFA): Require additional verification during login.
3. Rate limiting: Restrict repeated login attempts to prevent brute-force attacks.
4. Generic error messages: Avoid revealing whether a username or password is incorrect.
5. Secure password recovery: Use random, single-use, time-limited password-reset tokens.
6. Secure session management: Use secure cookies with HttpOnly, Secure, and SameSite attributes.
7. Login monitoring: Record suspicious login attempts and detect unusual activity.